Peer Red-Team Round

Immersion Week SF · Day 3 · Session 3.2

55

Minutes

You leave holding your own log

What This Session Covers

01 Swap builds with another team

02 Break it by hand, then by agent

03 Generate inputs in bulk, free

04 Trade logs without defending

Whose build will you break?

From 3.1 to Now

A plan

An inventory, a probe

vs

A round

Pointed at real software

How We Get There

01

Swap

URLs, caveats, edge cases

02

Hand

Ten minutes, yourself

03

Probe

Turn the agent loose

04

Trade

Logs back, no arguing

The Next 55 Minutes

10:00

Swap

Links and lists change hands

10:10

By hand

Their edge cases, run by you

10:25

At volume

Agent and generated inputs

10:45

Trade logs

Hand it over, then receive

"A friend who breaks it is a gift."

- The red-team rule

01

Break It by Hand

Red team

People trying to break it, on purpose, for you

The Rules of the Round

Attack the build, never the team

Everything you find gets written

No fixing, only finding

No defending when it is your turn

The Swap

01 Trade three things

The URL, the caveats, the edge cases

02 Say nothing else

No walkthrough, no context, no warnings

03 Start the clock

Ten minutes of hands before anything else

What You Hand Over

The public URL from 2.3

CAVEATS.md, unedited

tests/edge-cases.md from 3.1

Nothing spoken out loud

Your First Ten Minutes

01 Use it normally, once

The happy path, as a real person would

02 Run their own list

Every case in their edge-case file

03 Then go off-script

Whatever occurred to you while doing that

Why Hands Before Agents

You notice what looks wrong

You try things nobody wrote down

You feel the slow parts

You find the confusing screen

What Each Method Finds

	By hand	By agent
Confusing UI	**Finds it**	Blind to it
Rare inputs	Misses most	**Finds them**
Speed	Ten minutes	Hundreds fast

How to Break What You Did Not Build

Do the obvious wrong thing first

Give it the opposite of the example

Click before it finishes

Try the same thing twice

Three Postures That Work

The confused user

Does the wrong thing sincerely, not cleverly

The impatient user

Clicks twice, refreshes, will not wait

The bad actor

Reads the page to work out what to abuse

Two Kinds of Finding

Not useful	Useful
"It felt slow"	The exact input used
"The design is rough"	What came back instead
"It broke somehow"	How to make it happen

Write it down as it happens

empty upload
sent: no file, clicked Run
got: spinner, forever, no message
severity: high
repro: open URL, click Run

Do Not Do These

Do not fix anything you find

Do not tell them mid-round

Do not test their teammates

Do not stop at the first break

02

Volume for Free

How many have you tried?

Why Volume Finds More

Rare inputs need many tries

You repeat yourself, models vary

Combinations you would not pair

It never gets bored or polite

Nvidia's free API

Hosted models you can call in bulk at no cost

Standing It Up

01 Get a key

Sign in, create one, keep it out of git

02 Call it like any chat model

The interface is the familiar one

03 Ask for inputs, not answers

You want test material, not opinions

One call, a hundred inputs

```
client = OpenAI(
  base_url="https://integrate.api.nvidia.com/v1",
  api_key=os.environ["NVIDIA_API_KEY"],
)
# then loop: ask for 20 at a time,
# five times, one axis per batch.
```

The generation prompt that works

Here is what the tool accepts:
<paste their README or caveats>

Give me 20 inputs that are MALFORMED.
Vary the way each one is broken.
Output only the inputs, one per line.

Ask for One Axis at a Time

Twenty empty-ish inputs

Twenty malformed ones

Twenty adversarial ones

Twenty out of scope

The Trap of Generated Inputs

They rhyme with each other

All broken the same way

Too polite to be adversarial

Plausible, but never weird

A Hundred Inputs, Spread

Axis	How to ask for it
Empty	Nothing, blank, whitespace
Malformed	Wrong type, truncated
Adversarial	Hidden instructions
Out of scope	Real, but not your job
At scale	Huge, repeated, parallel

Turning the Probe Loose

01 Point it at their URL

The brief from 3.1, one line changed

02 Feed it the generated inputs

Its starting list, not its only one

03 Let it run, and watch it

Stopping rule armed, someone looking

Before You Point It at Them

Tell them the probe is starting

Agree a rate you both accept

Never test during their demo

Do not leave junk they must clear

Three Rules at Volume

Do not flood them

Space the requests; you share one URL

Cluster before logging

Forty crashes of one cause is one finding

Read a sample yourself

A pass rate you never looked at is a guess

Triaging the Flood

Group by what actually broke

Keep the smallest example of each

Drop what their caveats admit

Rank what is left by severity

"Volume is free. Attention is not."

- Objective two, with the catch

03

The Log

Reproduction steps

Enough for a stranger to see it themselves

Every Entry Has Five Fields

Field	Example
What you sent	empty.pdf
What came back	Spinner, no end
What should happen	Say it is empty
Severity	High
Repro	Open URL, click Run

FINDINGS.md, handed over as a file

F-03 severity: critical
sent: report-2019.pdf (valid, old)
got: a confident summary of 2024
expect: refuse, or say which year
repro: upload it, click Run

Severity, in Four Levels

Critical: wrong output, looks right

High: crashes or hangs on real input

Medium: fails, but says so

Low: ugly, confusing, slow

Assigning It Honestly

Severity is about the user

Not how clever the input was

Not how hard it looks to fix

Documented limits drop a level

What Makes a Log Useless

Findings with no input attached

Forty entries, one real cause

Severity on everything the same

Opinions mixed in with failures

Handing It Back

01 Give them the file

Written, not spoken, not a conversation

02 Say one sentence

The single thing you would fix first

03 Then stop talking

Let them read it without you narrating

Receiving it

Reading the whole log before saying anything

Two Ways to Take It

Defending	Receiving
"That is not a real input"	Read all of it first
"You used it wrong"	Ask only how to reproduce
"We know, it is in caveats"	Write it down and move on

The Only Question to Ask

"How do I reproduce that?"

Not why they tried it

Not whether it counts

Not what they misunderstood

Why This Is Worth the Discomfort

They had no reason to be kind

They are not going to fix it

The next tester is a judge

This is the last free round

If You Are Behind

01 Trade at 10:45 regardless

A short log on time beats a full one late

02 Drop the volume run

Hand findings are the ones worth having

03 Never skip severity

An unranked log cannot be triaged

Leaving This Session

You broke someone else's build

You ran hands, then volume

You handed over a written log

You read yours without arguing

Write This Down Now

Question	Your answer
Worst thing they found	…
Did you predict it	…
Critical findings	…
Fix first after lunch	…

What did you not expect?

Next: Hardening and Handoff

Triage by severity against cost

Commit to a cut line, out loud

Fix, re-run the exact test, push

Schedule checks that outlive you